

MAPEO NORMATIVO DETALLADO

Cada Métrica GQM-DREAD mapeada a Requisitos Normativos Aplicables

España 2025-2026 • NIS2 • ENS • DORA • GDPR • ISO 27001 • NIST CSF • CRA • IEC 62443 • MAGERIT

"La regulación sin métricas es declaración de buenas intenciones. Las métricas sin regulación son datos huérfanos. El mapeo normativo es el acto de casamentero que los une... con todas sus consecuencias."

GUÍA DE LECTURA

La tabla siguiente mapea cada una de las **23 métricas del Kit GQM-DREAD** a los requisitos específicos de los marcos normativos más relevantes para España en 2025-2026:

- NIS2: Directiva (UE) 2022/2555 (transpuesta mediante LCGC-2025)
- ENS: Esquema Nacional de Seguridad (RD 311/2022)
- DORA: Reglamento (UE) 2022/2554 (en vigor desde enero 2025)
- GDPR: Reglamento (UE) 2016/679 + LOPDGDD
- ISO 27001:2022: Norma internacional de SGSI
- NIST CSF 2.0: Marco del NIST para la mejora de la ciberseguridad
- CRA: Reglamento de Ciberresiliencia (UE) 2024/2847
- IEC 62443: Estándar de seguridad para sistemas de control industrial
- MAGERIT v3: Metodología de Análisis y Gestión de Riesgos de las AAPP españolas
- INCIBE-IMC: Marco de Indicadores de Ciberresiliencia (INCIBE)

Columnas de la tabla:

- **Obligatorio:** La métrica es necesaria para demostrar cumplimiento del requisito normativo
- **Recomendado:** La métrica es la mejor práctica para el cumplimiento, aunque no explícitamente requerida
- **Evidencia:** Qué aporta la métrica como evidencia de auditoría

TABLA MAESTRA DE MAPEO NORMATIVO

DIMENSIÓN D — DAÑO

ID Métrica	Nombre	NIS2	ENS	DORA	GDR	ISO 27001:2022	NIST CSF 2.0	CRA	MAG ERIT v3	INCIBE-IMC	Tipo Req.	Evidencia de auditoría
D.M1	ALE por amenaza crítica	Art.2 1.2.a (gestión de riesgos)	Anexo II Med. 2 (análisis de riesgos)	Art.6.a (gestión del riesgo o TIC)	—	A.6.1.2 (tratamiento del riesgo)	GV.RM (Govern.Risk Mgmt)	Art.1 3.2	Fase 3 (evaluación)	IMC-R1	Obligatorio (NIS 2/DO RA)	Registro de análisis de riesgos con valoración económica, aprobado por el órgano de dirección

D.M2	IEAC	Art.2 1.2.f (seguridad de activos)	Org.1 (inventari o activos)	Art.8. b (mapeo activos críticos)	—	A.8.1. 1 (inventari o activos)	ID.A M (Identify.A sset Mgmt)	Art.1 3.3	Fase 2 (inventari o)	IMC- R2	Oblig atori o (NIS 2/ENS)	Inve ntari o de activ os clasif icado s por critic idad con porce ntaje de expo sició n docu ment ado
D.M3	RTO gap	Art.2 1.2.c (cont inuid ad del nego cio)	Op.co nt.1 (cont inuid ad)	Art.11 .a (cont inuid ad TIC)	—	A.17.1 (plan ificac ión conti nuid ad)	RC.R P (Rec over. Reco very Plan)	—	Plan de Conti nuid ad	IMC- BC1	Oblig atori o (DOR A/NIS2)	Resul tados de ejerci cios BCP/ DRP con comp arati va RTO objet ivo vs. RTO alcan zado; firma del CISO y CO

D.M4	TBN O	Art.2 3.1 (noti ficaci ón de incid entes)	Op.ex p.6 (dete cción incid entes)	Art.1 9 (noti ficaci ón)	Art.3 3-34 GDP R	A.16.1 .2 (noti ficaci ón)	RS.C O (Res pond. Com unic.)	—	—	IMC- N1	Oblig atori o (GDP R/NIS 2)	Regis tro DPO con times tamp s de detec ción, clasif icaci ón y notifi cació n; confi rmac ión de recep ción AEP D
D.M5	TMC D	Art.2 3.1 (alert a temp rana ≤ 24h)	Op.ex p.4 (mon itoriz ación)	Art.1 9.4 (alert a temp rana)	—	A.16.1 .5 (resp uesta a incid entes)	RS.A N (Res pond. Anal ysis)	—	—	IMC- D1	Oblig atori o (NIS 2 Art.2 3.1)	Log del siste ma ITSM con times tamp s de clasif icaci ón; evide ncia de alert as temp ranas al CNCS en < 24h

DIMENSIÓN R — REPRODUCIBILIDAD

ID Métrica	Nom bre	NIS2	ENS	DOR A	GDP R	ISO 2700 1:20 22	NIST CSF 2.0	CRA	IEC 6244 3	INCIB E- IMC	Tipo Req.	Evide ncia de audit oría
R.M1	MTT R por DRE AD-R	Art.2 1.2.e (gesti ón de vulne rabili dade s)	Mp.s w.2 (gesti ón de parc hes)	Art.9. 2 (gesti ón de parc hes TIC)	—	A.12. 6.1 (gesti ón de vulne rabili dade s técni cas)	ID.R A (Iden tify.R risk Asses smen t)	Art.1 3.2.c (parc heo oport uno)	SR 2.2 (gesti ón de actua lizaci ones)	IMC- V1	Oblig atori o (NIS 2/CR A)	Regis tro de vulne rabili dade s con fecha s de publi cació n CVE, fecha s de reme diaci ón y SLAs; infor me de exce pcion es con justif icaci ón

R.M2	TVE R (EPS S)	Art.2 1.2.e (prio rizaci ón de vulne rabili dade s)	Mp.s w.2 (prio rizaci ón riesg os)	Art.9. 2 (prio rizaci ón)	—	A.12. 6.1 (prio rizaci ón vulne rabili dade s)	ID.R A-1 (iden tifica ción amen azas)	Art.1 3.2.c	SR 2.2	IMC- V2	Reco men dado	Dash boar d VM con integ ració n EPSS; evide ncia de prior izaci ón de vulne rabili dade s EPSS > 0.5; ratio s de reme diaci ón por cuart il EPSS
------	------------------------	---	--	---------------------------------------	---	--	---	----------------	-----------	------------	---------------------	---

R.M3	ICEP	Art.2 1.2.e (mon itoriz ación amen azas)	Op.ex p.2 (mon itoriz ación amen azas exter nas)	Art.9. 2	—	A.6.1. 4 (intel igenc ia de amen azas)	ID.R A-2 (feed s de inteli genci a)	Art.1 3.2.c	SR 2.2	IMC- TII	Reco men dado	Regis tro de amen azas con verifi cació n de explo it públi co en bases exter nas (Expl oitDB , NVD); corre lació n con plan de reme diaci ón
------	------	--	--	-------------	---	--	---	----------------	-----------	-------------	---------------------	--

R.M4	VEE	Art.2 1.2.e (venta ana de expo sición)	Mp.s w.2	Art.9. 2	—	A.12. 6.1	ID.R A-1	Art.1 3.2.c	SR 2.2	IMC- V3	Reco men dado	Análi sis de venta na de expo sición por activ o crític o; evide ncia de ASM con times tamp s de prim era detec ción exter na
-------------	-----	--	-------------	-------------	---	--------------	-------------	----------------	-----------	------------	---------------------	---

DIMENSIÓN E — EXPLOTABILIDAD

ID Métrica	NOMBRE	NIS2	ENS	DORA	GDR	ISO 27001:2022	NIST CSF 2.0	CRA	IEC 62443	INCIBE-IMC	Tipo Req.	Evidencia de auditoría
E.M1	SMEC CVSS v4.0	Art.2 1.2.e (evaluación riesgos técnicos)	Mps.w.2 (severidad parches)	Art.9.2 (evaluación riesgo TIC)	—	A.12.6.1 (scoring vulnerabilidades)	ID.R A-1	Art.1 3.2.b	SR 2.2	IMC-V1	Recomendado	Informes VM con CVSS scores de vulnerabilidades activas; distribución por niveles de severidad; tendencia trimestral

E.M2	TCKE V (CIS A KEV)	Art.2 1.2.e + Art.2 1.3 (med idas apro piada s, KEV como evide ncia)	Mp.s w.2 (parc hes crític os)	Art.9. 2	—	A.12. 6.1	PR.IP -12 (gesti ón vulne rabili dade s)	Art.1 3.2.c	SR 2.2	IMC- V2	Oblig atori o de facto (NIS 2 Art.2 1.3: "esta do del arte")	Cruc e diari o del inve ntari o de vulne rabili dade s activ as contr a CISA KEV; evide ncia de reme diaci ón inme diata de coinc idenc ias; regist ro audit ado
------	--------------------------------	---	--	-------------	---	--------------	---	----------------	-----------	------------	---	--

E.M3	DRE AD-E LLM	Art.2 1.2.e (nue vos vecto res de amen aza)	—	Art.9. 3 (eval uació n avan zada de amen azas)	Art.2 5 (priv acy by desig n en siste mas IA)	A.6.1. 4 (intel igenc ia de amen azas emer gente s)	ID.R A-3 (nue vos vecto res)	Art.1 3 (segu ridad por diseñ o en prod uctos digit ales)	—	IMC- TI2	Reco men dado	Infor me de red team LLM /IA con score s DRE AD-E para cada vecto r de ataq ue ident ificad o; plan de mitig ación
------	--------------------	---	---	---	--	--	---	---	---	-------------	---------------------	--

E.M4	TMC E	Art.2 1.2.b (detección y respuesta a incidentes)	Op.ex p.5 (gestión de incidentes)	Art.1 9.4 (alerta temprana)	—	A.16.1 .5 (respuesta a incidentes)	RS.A N-3 (análisis incidentes)	—	SR 6.2 (respuesta a incidentes)	IMC- D2	Oblig atorio (NIS 2/DO RA)	Log SIEM /SOA R con times tamps de detección, alerta y contención; comparativa con SLAs definidos; informe mensual al CISO
------	----------	--	--	--------------------------------------	---	---	---	---	--	------------	--	---

E.M5	ICCA E	Art.2 1.2.g (auten- tificación, acceso o privile- giado)	Mp.if .7 (segmen- tación), Mp.si .3 (MFA)	Art.9. 3 (controles de acceso o TIC)	Art.3 2.1.a (medidas técnicas)	A.9.1. 2 (control de acceso), A.13.1 (segmen- tación)	PR.A C (Protección de la Identidad y Mgmt)	Art.1 3.2.d (controles de seguridad)	SR 2.1 (denegación de acceso o no autorizado)	IMC- C1	Obligato- rio (NIS 2/EN S/DORA)	Inventari- o de activos con estado de implemen- tación de controles (MFA, PAM, micro- segmenta- ción); resultados de auditoría de configura- ción; cobertura por tier
------	-----------	--	---	--	---	---	---	---	--	------------	---	--

DIMENSIÓN A — USUARIOS AFECTADOS

ID Métrica	NOMBRE	NIS2	ENS	DORA	GDR	ISO 27001:2022	NIST CSF 2.0	CRA	MAGERIT v3	INCIBE-IMC	Tipo Req.	Evidencia de auditoría
A.M1	UMPA	Art.23.3 (criterios de "gran magnitud": >50.000 usuarios)	—	Art.19.3 (umbral notificación)	Art.33.1 (umbral notificación significativa)	A.17.1.1 (alcance del BCP)	ID.AM-2 (alcance de impacto)	Art.13.2 (impacto en usuarios)	Fase 3 (valoración de impacto)	IMC-II	Obligatorio (NIS 2 Art.23.3)	Base de datos de usuarios del servicio crítico o con cifras actualizadas; mapeado de dependencias de servicio; validación por responsable del servicio

A.M2	IUVA	—	—	—	Art.9 (categorías especiales) , Art.3 2.1 (medidas adicionales)	A.8.2. 1 (clasificación datos)	ID.A M-5 (datos sensibles)	—	Fase 2 (clasificación activos)	IMC- I2	Obligatorio (GDP R Art.9)	Mapa de clasificación de datos GDP R Art.9; identificación de sistemas con datos de categoría especial; porcentaje de usuarios en cada categoría
-------------	-------------	---	---	---	--	---	-------------------------------------	---	---	------------	------------------------------------	--

A.M3	TMN U	Art.2 3.2 (notificación a usuarios afectados)	—	Art.1 9.5 (comunicación a afectados)	Art.3 3 (< 72h AEPD), Art.3 4 (comunicación a interesados)	A.16.1 .6 (aprendizaje de incidentes)	RS.C O-3 (comunicación incidentes)	—	—	IMC-N2	Obligatorio (GDP R Art.3 3-34)	Registros DPO con timestamps; acusos de recibido de la AEPD; evidencia de comunicación a usuarios afectados; plantillas de notificación aprobadas
------	----------	---	---	--	---	---	--	---	---	--------	-----------------------------------	---

A.M4	CUA	Art.2 1.2.a (anál isis de impa cto finan ciero)	—	Art.6. a (imp acto finan ciero cuan tifica do)	Art.3 5 (EIP D para proce sami ento de alto riesg o)	A.6.1. 2 (valo ración del impa cto)	GV.R M-6 (cua ntific ación del riesg o)	—	Fase 3 (imp acto econ ómico)	IMC- R3	Reco men dado	Infor me post- incid ente con conta biliza ción de coste s direc tos e indir ectos ; cálcu lo del coste por usua rio afect ado; comp arati va con benc hmar ks INCI BE/P one mon
------	-----	---	---	--	---	---	--	---	---	------------	---------------------	---

A.M5	CCUC	Art.2 1.2.c (cont inuid ad de los servi cios esenc iales)	Op.co nt.1 (BCP)	Art.11 (cont inuid ad de los servi cios TIC)	—	A.17.1 .2 (impl emen tación de conti nuid ad)	RC.R P-1 (plan de recu perac ión)	—	Plan de Conti nuid ad	IMC- BC2	Oblig atori o (NIS 2/DO RA para esenc iales)	Inve ntari o de usua rios por servi cio con estad o de cober tura BCP/ DRP; resul tados de ejerci cios de conti nuid ad; certif icaci ón de RTO/ RPO por servi cio
------	------	--	----------------------------	---	---	---	---	---	-----------------------------------	-------------	--	---

DIMENSIÓN Disc — DESCUBRIBILIDAD

ID Métrica	Nombre	NIS2	ENS	DORA	GDR	ISO 27001:2022	NIST CSF 2.0	CRA	IEC 62443	INCIBE-IMC	Tipo Req.	Evidencia de auditoría
Disc. M1	RSAE	Art.2 1.2.e (gestión de la superficie de ataque)	Mp.com.1 (perímetro de red)	Art.9.4 (monitoreo del entorno)	—	A.13.1.1 (controles de red)	ID.A M-3 (inventario de red)	Art.1 3.2.d (superficie de ataque)	SR 5.2 (control de zonas)	IMC-EA1	Recomendado	Informes ASM periódicos con inventario de activos externamente visibles; comparativa con baseline; registro de cambios de exposición

Disc. M2	RDP R	Art.2 1.2.h (prue bas de efica cia de contr oles)	Op.ex p.3 (mon itoriz ación proac tiva)	Art.2 6 (prue bas de penet ración)	—	A.16.1 .4 (valo ración de incid entes)	DE.C M (Dete ct.M onito ring)	Art.1 3.2.c	SR 6.1 (audi toría de segur idad)	IMC- D3	Reco men dado	Regis tro de oríge nes de desc ubri mien to de vulne rabili dade s (inte rno/ exter no); resul tados de red team ; eviden cia de progr ama de threa t hunti ng
-------------	----------	--	---	--	---	--	--	----------------	---	------------	---------------------	---

Disc. M3	NSIE	Art.2 1.2.d (hardening de sistemas)	Mp.com.2 (protección de la red), Op.ex p.1 (registro de actividad)	Art.9.3 (gestión de la configuración TIC)	—	A.12.6.2 (restricción de software), A.13.1 (seguridad de red)	PR.IP-1 (base line de configuración)	Art.13.2.d (principio mínimo privilegio)	SR7.6 (control de puertos y servicios)	IMC-EA2	Obligatorio (ENS/CRA)	Resultados de escaneo de puertos firmados con fecha; registro de justificaciones para puertos abiertos; comparativa vs. baseline de hardening aprobado
-----------------	------	---	---	--	---	--	---	---	---	---------	--------------------------	--

Disc. M4	TMD E	Art.2 1.2.e (detección temporana de exposición)	Op.ex p.4 (monitoreización continua)	Art.9. 4 (detección temporana)	—	A.12. 6.1 (detección de vulnerabilidades nuevas)	DE.C M-8 (escaneo de vulnerabilidades)	Art.1 3.2.c (monitoreización activa)	SR 6.1	IMC- D4	Recomen- dado	Registros ASM con tiempos de primera detección externa vs. fecha de publicación CVE; análisis de tendencia de TMD E; plan de mejora
-------------	----------	--	---	---	---	---	--	---	-----------	------------	------------------	--

TABLA RESUMEN: MÉTRICAS POR OBLIGATORIEDAD NORMATIVA

Métricas de cumplimiento obligatorio (imprescindibles para audit trail regulatorio)

Métrica	Marco normativo principal	Artículo/Requisito específico
D.M1 — ALE	NIS2 + DORA	NIS2 Art.21.2.a; DORA Art.6.a
D.M2 — IEAC	NIS2 + ENS	NIS2 Art.21.2.f; ENS Org.1
D.M3 — RTO gap	DORA + NIS2	DORA Art.11; NIS2 Art.21.2.c
D.M4 — TBNO	GDPR + NIS2	GDPR Art.33-34; NIS2 Art.23.1
D.M5 — TMCD	NIS2	NIS2 Art.23.1 (alerta 24h)
R.M1 — MTTR	NIS2 + CRA	NIS2 Art.21.2.e; CRA Art.13.2.c
E.M2 — TCKEV	NIS2 Art.21.3 ("estado del arte")	Evidencia de gestión proactiva de KEV
E.M4 — TMCE	NIS2 + DORA	NIS2 Art.21.2.b; DORA Art.19.4
E.M5 — ICCAE	NIS2 + ENS + DORA	NIS2 Art.21.2.g; ENS Mp.si.3; DORA Art.9.3
A.M1 — UMPA	NIS2	NIS2 Art.23.3 (umbral "gran magnitud")
A.M2 — IUVA	GDPR	GDPR Art.9 (datos categoría especial)
A.M3 — TMNU	GDPR + NIS2	GDPR Art.33 (72h AEPD); NIS2 Art.23.2
A.M5 — CCUC	NIS2 + DORA	NIS2 Art.21.2.c; DORA Art.11
Disc.M3 — NSIE	ENS + CRA	ENS Mp.com.2; CRA Art.13.2.d

Métricas de mejor práctica recomendada

Métrica	Marco normativo de referencia	Fundamento
R.M2 — TVER (EPSS)	NIS2 Art.21.2.e + "estado del arte"	EPSS como metodología avanzada de priorización
R.M3 — ICEP	NIS2 Art.21.2.e + NIST CSF	Inteligencia de amenazas con exploits públicos
R.M4 — VEE	NIS2 Art.21.2.e + CRA Art.13	Gestión proactiva de la ventana de exposición
E.M1 — SMEC	NIS2 Art.21.2.e + NIST CSF	Scoring de severidad con CVSS v4.0 (actualización "estado del arte")
E.M3 — DREAD-E LLM	NIS2 Art.21.2.e + CRA Art.13 (nuevos vectores)	Evaluación de explotabilidad en sistemas IA
A.M4 — CUA	DORA Art.6.a + MAGERIT	Cuantificación financiera por usuario afectado
Disc.M1 — RSAE	NIS2 Art.21.2.e + CRA Art.13.2.d	ASM como práctica de gestión proactiva de superficie de ataque
Disc.M2 — RDPR	NIS2 Art.21.2.h + DORA Art.26	Ratio de eficacia del programa de detección
Disc.M4 — TMDE	NIS2 Art.21.2.e + NIST CSF DE.CM	Monitorización continua de exposición externa

NOTA SOBRE LA TRANSPOSICIÓN NIS2 EN ESPAÑA (LCGC-2025)

La Ley de Coordinación y Gobernanza de la Ciberseguridad (LCGC), que transpone NIS2 en España, mantiene los requisitos de notificación de incidentes (Art.23 NIS2) y los requisitos de medidas de gestión de riesgos (Art.21 NIS2) con los mismos plazos y umbrales. Las organizaciones esenciales e importantes identificadas por el CNCS deben implementar los 10 grupos de medidas del Art.21.2 NIS2, para los cuales las métricas de este kit proporcionan la evidencia cuantitativa necesaria para demostrar su implementación efectiva.

Para el **sector financiero** (bancos, aseguradoras, gestoras, infraestructuras de mercado), DORA se aplica de forma directa desde enero de 2025 como lex specialis sobre NIS2 en lo relativo a la resiliencia operativa digital. Las métricas D.M3, E.M4, A.M5 y E.M5 son especialmente críticas para la demostración de cumplimiento DORA ante el Banco de España y la CNMV.

Mapeo Normativo · Documento D del Kit GQM+PRAGMATIC DREAD · Abril 2026

Fuentes normativas: NIS2 (2022/2555/UE), ENS (RD 311/2022), DORA (2022/2554/UE), GDPR (2016/679) CRA (2024/2847/UE), ISO/IEC 27001:2022, NIST CSF 2.0, IEC 62443-2-1, MAGERIT v3, INCIBE-IMC